



A managed, cloud-native platform — secure, compliant, EU-hosted.

No hand-operated servers to patch or fail. Data and identity run on managed PostgreSQL in AWS London; the security boundary is enforced in the database. Reviewed against OWASP Top 10 and remediated.

§ 01 PLATFORM AT A GLANCE

LAYER	WHAT RUNS IT	WHERE
Frontend	Static application delivered from a global CDN edge	Multi-region edge
Data & auth	Managed PostgreSQL + identity (Supabase)	AWS · eu-west-2 · London
Security boundary	PostgreSQL Row-Level Security (RLS)	Enforced in the database

The browser only ever holds a publishable key; all data access is mediated by Row-Level Security. There is no application server holding privileged credentials to compromise.

§ 02 DATA RESIDENCY & COMPLIANCE

- **UK / EU data residency** — all customer data stored in AWS London (eu-west-2). Clean UK-GDPR / EU answer.
- Controls map to the standards the product teaches: **EU AI Act (Art. 4), GDPR, ISO/IEC 42001, ISO/IEC 27001**.

§ 03 AUTHENTICATION

- Email + password with **mandatory MFA** (TOTP, AAL2) — no portal content renders until MFA is satisfied.
- Same-origin redirect protection; **breached-password screening** and rate-limiting enabled.

§ 04 ACCESS CONTROL & TENANT ISOLATION

- **Row-Level Security on every table**, scoped per user — verified live: an unauthenticated request returns no data.
- **Least privilege** — end-users, customer admins and partners each see only their own tenant's rows; privileged operations (seat assignment, credits) run only through controlled server-side routines.
- Confirmed by independent review and the platform's own automated security advisor.

§ 05 AUDITABILITY

- **Append-only, tamper-resistant audit log** of privileged actions — immutable and invisible to end-users, readable only by administrators.
- Training completion is **graded server-side** (answer keys never reach the browser) — completion evidence cannot be forged.

§ 06 SCALABILITY & RESILIENCE

- Serves **50,000+ users with no re-architecture** — CDN frontend + vertically-scaled managed database.
- **Daily backups + Point-in-Time Recovery**; documented restore procedure. No single self-managed server to patch or fail.

§ 07 APPLICATION SECURITY POSTURE

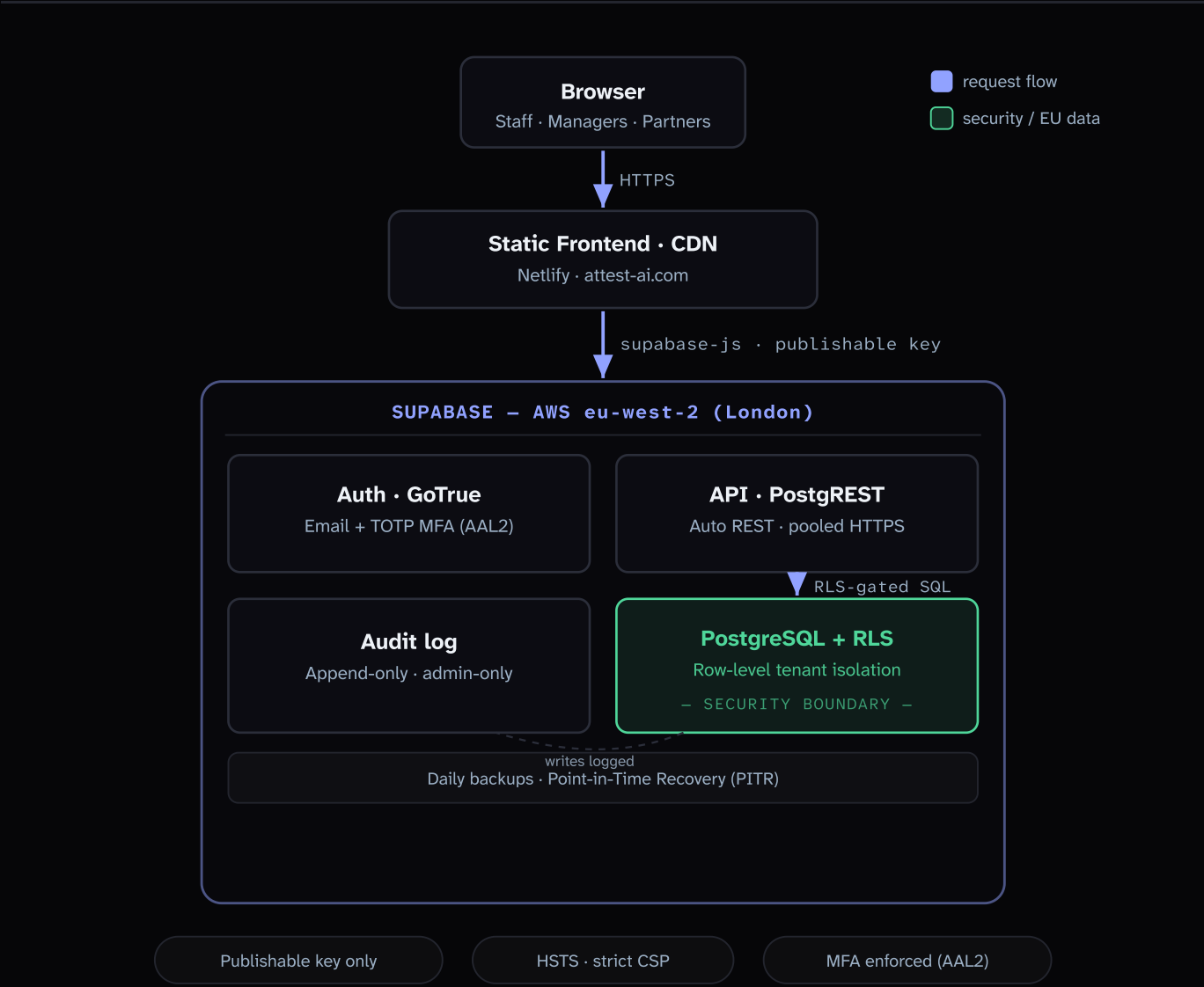
- **Full OWASP Top 10 review completed and remediated** ✓ — Critical / High / Medium all fixed, with a dated, version-controlled migration trail as evidence.
- **HTTPS everywhere** with HSTS preload; **strict Content-Security-Policy** (no inline script); clickjacking protection (`frame-ancestors 'none'`); MIME-sniffing and referrer hardening.
- **No secrets in source control**; third-party dependencies pinned; supply-chain hygiene.

§ 08 WHY THIS STACK — FOR THE TECHNICAL REVIEWER

Modern SaaS frontends are static apps on a CDN; the seriousness is in the **data, identity and control plane** — here, **managed PostgreSQL on AWS London with enforced RLS, MFA and audit**. A deliberately boring, defensible, compliance-aligned architecture — not a bespoke server estate to operate.

System architecture.

Request flow and trust boundaries. Blue = request flow · green = security boundary & EU data residency.



Browser → static CDN frontend → Supabase (auth, API, RLS-protected PostgreSQL, audit) on AWS London. No application server; the security boundary is enforced inside the database.